



1.1. PRINCIPIOS DE SEGURIDAD Y ALTA DISPONIBILIDAD

PARTE 1 – PRINCIPIOS BÁSICOS DE SEGURIDAD Y ALTA DISPONIBILIDAD

ISABEL YEBRA RUIZ
IES ALONSO AVELLANEDA

Contenido

Contenido	1
1 Definición de información.....	2
2 Definición de seguridad	2
3 Problemática redes de comunicaciones.....	2
4 ¿Qué debemos proteger?	3
4.1 Confidencialidad (o privacidad):.....	4
4.2 Integridad (o confiabilidad)	4
4.3 Disponibilidad (o accesibilidad).....	5
4.4 Autenticidad /Autenticación.....	6
4.5 No repudio.....	6
5 Tipos de amenazas	7
5.1 Amenazas producidas por personas.....	7
5.2 Amenazas lógicas	8
5.3 Amenazas físicas	9
6 Tipos de ataques	10
7 Análisis y gestión de riesgo	11
8 Proceso de análisis de riesgos informáticos	11
9 Herramientas de análisis y gestión de riesgos.	12
9.1 Política de seguridad	12
9.2 Ejemplos de herramientas de análisis y gestión de riesgos	12
10 Auditoría	13
11 Plan de contingencias	14

1 Definición de información

En el entorno empresarial, se define información como el activo que posee valor para una organización y requiere, por tanto, de una protección adecuada para asegurar la continuidad del negocio, minimizar los daños a la organización y maximizar el retorno de las inversiones y las oportunidades de negocio.

2 Definición de seguridad

La **seguridad informática** es el conjunto de **herramientas, técnicas, dispositivos y procedimientos** orientados a conseguir, mejorar o garantizar determinados niveles de **confidencialidad, disponibilidad, integridad, autenticidad y/o no repudio** de la información con la que trabaja un sistema informático.

NOTA: Podemos encontrar estas definiciones en la norma **ISO 27002**, que tiene su traducción al español en la norma **UNE-ISO/IEC 17799**.

El experto Eugene H. Spafford cita en su frase célebre:

“El único sistema que es totalmente seguro es aquel que se encuentra apagado y desconectado, guardado en una caja fuerte de titanio que está enterrada en cemento, rodeada de gas nervioso y de un grupo de guardias fuertemente armados. Aún así, no apostaría mi vida en ello”.



3 Problemática redes de comunicaciones

- Compartimos recursos
- Sistema complejo
- Perímetro desconocido
- Múltiples puntos de ataque

Esto genera vulnerabilidades en el sistema. Una **vulnerabilidad** es una debilidad de un activo o grupo de activos que puede ser explotada por una o más amenazas.

Últimas vulnerabilidades

Estas vulnerabilidades de un sistema informático deben analizarse. Esto implica el uso de herramientas especializadas para examinar sistemas en busca de posibles fallos de seguridad, configuraciones incorrectas o debilidades en el software. Estas herramientas realizan pruebas exhaustivas para identificar vulnerabilidades conocidas y desconocidas que podrían ser explotadas por amenazas cibernéticas.

Además de las herramientas automatizadas, el análisis manual es fundamental. Los expertos en seguridad realizan inspecciones detalladas y personalizadas en busca de vulnerabilidades específicas que las herramientas automatizadas podrían pasar por alto. Este enfoque brinda una comprensión más profunda de los sistemas y sus posibles riesgos.

4 ¿Qué debemos proteger?



Los sistemas informáticos, ya sean SSOO, servicios o aplicaciones, se dice que son seguros si cumplen las siguientes características u objetivos:



4.1 Confidencialidad (o privacidad):

La confidencialidad es la garantía de que la información sea accesible solo por aquellos usuarios o sistemas autorizados.

Ejemplo: cifrar un archivo con contraseña que solo conocen unos pocos usuarios.

4.2 Integridad (o confiabilidad)

La integridad es lograr que la información sea la misma desde que fue generada, es decir, que no se haya manipulado o corrompido (no puede ser modificada por personas no autorizadas.)

Ejemplos: generar un código hash para un archivo de datos, firmas digitales, control de versiones, sistema de detección de intrusos (que alerten sobre cambios no autorizados en los datos)

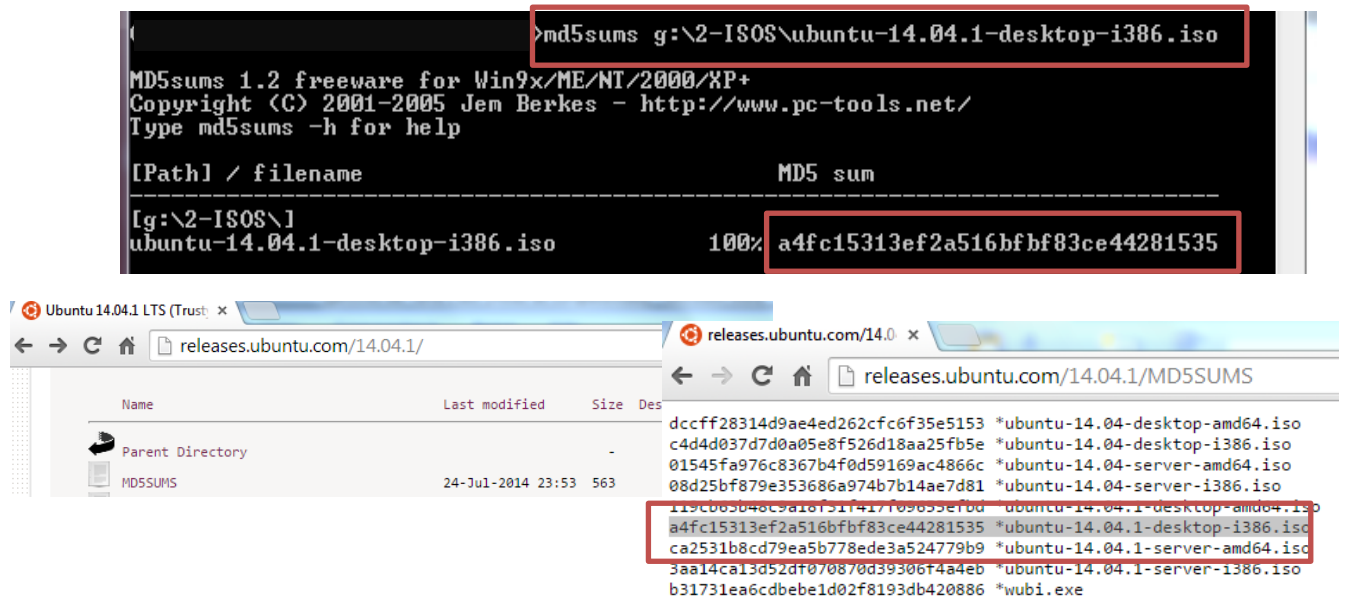
Comprobación de integridad, no falsificación o modificación de archivos en el sistema (*anti-rootkit*), en Windows (*md5sum*, *SFC (System File Checker)*) y GNU/Linux (*cksum*, *Rootkit hunter*).

Ejemplo práctico: cksum en Linux

```
@ldapserver: ~  
@ldapserver:~$ echo "Prueba de integridad en Linux" > fichero  
@ldapserver:~$ cksum fichero  
146841094 30 fichero  
@ldapserver:~$ echo "Prueba de integridad en pinux" > fichero  
@ldapserver:~$ cksum fichero  
1815305712 30 fichero  
@ldapserver:~$
```

Un **pequeño cambio** en el contenido del archivo se transforma en un **gran cambio** en el valor del **sum**.

Ejemplo práctico: md5sums en Windows y en Linux



The image shows two screenshots. The top one is a Windows command prompt where the command `md5sums g:\2-ISOS\ubuntu-14.04.1-desktop-i386.iso` has been executed. The output shows the file name and its MD5 hash: `ubuntu-14.04.1-desktop-i386.iso 100% a4fc15313ef2a516bfbf83ce44281535`. The bottom screenshot shows the Ubuntu 14.04.1 LTS website, specifically the MD5SUMS page. It lists various ISO files and their corresponding MD5 hashes. The hash `a4fc15313ef2a516bfbf83ce44281535` is highlighted, matching the one from the Windows command prompt.

[Guía para probar en W10 o W11 de forma nativa con Powershell](#)

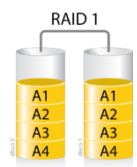
4.3 Disponibilidad (o accesibilidad)

La disponibilidad es conseguir que aquellos usuarios o sistemas con privilegios para acceder a la información puedan realizarlo sin ningún problema durante los periodos de tiempos establecidos y además se recupere automáticamente ante errores

Ejemplos:

- Implantar un Sistema de Alimentación Ininterrumpida (SAI).
- Creación de sistemas RAID (FreeNAS)
- Creación de una imagen de disco en Linux

`dd if=/dev/sda of=/dev/sdb`



- CPD
- *Comprobación de disponibilidad de servicios, protocolos y aplicaciones inseguras: NMAP, MBSA (Microsoft Baseline Security Analyzer), etc.*
- Alta disponibilidad (High Availability): aplicaciones y datos que se encuentren operativos en todo momento y sin interrupciones, **carácter crítico**.
- *Mantener sistemas funcionando **24 horas, 7 días a la semana y 365 días al año** a salvo de interrupciones. El mayor nivel acepta 5 minutos de inactividad al año (disponibilidad de 5 nueves: 99,999%).*

4.4 Autenticidad /Autenticación

La autenticidad asegura la identidad del equipo, los mensajes o usuario que genera la información. En ocasiones se utilizan terceras partes confiables (Autoridad de Certificación) para autenticar.

Ejemplos: Firma digital de un fichero, certificado digital, login + password.

4.5 No repudio

El no repudio es generar un mecanismo que permita que ninguno de los participantes de una comunicación niegue su participación en la misma. Existen dos tipos:

- **NO repudio en el origen:** el usuario o sistema que envía un mensaje no puede negar que lo mandó, pues el receptor tiene mecanismos para demostrarlo:

Ejemplo: un mensaje firmado digitalmente por el emisor.

- **NO repudio en el destino:** el usuario o sistema que recibe un mensaje no puede negar que lo recibió, pues el emisor tiene mecanismos para demostrarlo.

Ejemplo: un mensaje firmado digitalmente por el emisor.

Para conseguir el no repudio se cuenta en ocasiones con terceras partes confiables (Autoridad de Certificación).

El no repudio en el origen y la autenticidad son objetivos estrechamente relacionados.

Servicio	Ataque
Disponibilidad	Interrupción (p.e: DoS)
Confidencialidad	Intercepción (p.e: Man in the middle)
Integridad	Modificación (p.e: SQL Injection)
Autenticación	Falsificación (p.e: Robo de credenciales)
No repudio	Negación (p.e: operación desde WIFI ajena)

Impacto: Es la medición y valoración del daño que puede producir a la organización un incidente de seguridad

5 Tipos de amenazas

La **ingeniería social** es una técnica de manipulación que aprovecha el eslabón más débil del sistema de la información, el humano, para acceder a la información privada que tiene un valor inconmensurable.

Se trata de una de las técnicas más usadas por los ciberdelincuentes para ganarse la confianza del usuario desprevenido y conseguir que entregue sus claves privadas o compre en sitios web fraudulentos

Los tipos de amenazas los podemos clasificar en tres:

- Amenazas producidas por personas
- Amenazas lógicas
- Amenazas físicas

5.1 Amenazas producidas por personas

Son la principal fuente de amenaza para un sistema, Personal de la organización, Ex-empleados, Curiosos, Hackers, Crackers, Ciberterrorista, Sniffers, Carders.

- **Personal de la organización:** A veces amenaza de forma accidental, pero si lo hace de forma intencionada es muy dañino, pues es quien mejor conoce lo que es valioso para la empresa y quien mejor puede conocer la infraestructura y el equipamiento.
- **Ex-empleados:** En numerosas ocasiones aprovechan la falta de mantenimiento de las organizaciones, que no siempre mantienen actualizados los perfiles de acceso a sus sistemas. Un ex-empleado tiene una motivación extra al amenazar un sistema.
- **Curiosos:** Personas que, en general, realizan ataques pasivos (Obtener información sin destruir o modificar la original).
- **Hackers:** Aunque no siempre lo hacen con un objetivo perjudicial, los hackers son expertos informáticos en acceder a sistemas protegidos. Muchos de ellos acaban convirtiéndose en analistas de seguridad.
- **Crackers:** Son hackers con objetivos perjudiciales, En numerosas ocasiones, contratados para realizar espionaje empresarial.
- **Ciberterrorista:** Expertos en informática e intrusiones en la red que trabajan para países y organizaciones como espías y saboteadores informáticos.

- **Sniffers:** Expertos en redes que analizan el tráfico para obtener información extrayéndola de los paquetes que se transmiten por la red.
- **Carders:** Personas que se dedican al ataque de los sistemas de tarjetas, como los cajeros automáticos.

5.2 Amenazas lógicas

Entre las amenazas lógicas podemos nombrar:

- **Vulnerabilidades de software:** Se producen debido a errores en la programación (**bugs**) o a situaciones no previstas (**excepciones**). Al software que aprovecha dichos fallos para atacar se le llama **exploit**.
- **Canales ocultos:** Es un canal que puede ser usado para transferir información desde un equipo de un sistema a otro remoto, usando medios no destinados para este propósito por los desarrolladores del sistema. Por ejemplo, un **keylogger**, que envía toda la información tecleada en un equipo a un atacante remoto a través puertas traseras para descubrir información accidental.
- **Virus:** Un virus informático es un programa malicioso que se introduce en un ordenador, sin permiso o sin conocimiento de su usuario, para alterar su funcionamiento y, particularmente, con la finalidad de modificar o dañar el sistema. Por norma general, se asocian a un archivo ejecutable, quedando el equipo infectado cuando se abre dicho archivo.
- **Worms (gusanos):** parecidos a los virus, pero con la capacidad de autopropagarse a través de las redes, normalmente mediante correo basura o spam
- **Caballos de Troya o Troyanos:** Es un malware que se presenta al usuario como un programa aparentemente legítimo e inofensivo, pero que, al ejecutarlo, le brinda a un atacante acceso remoto al equipo infectado.
- **Rootkits:** Es un conjunto de software que permite un acceso de privilegio continuo a un ordenador pero que mantiene su presencia activamente oculta al control de los administradores al corromper el funcionamiento normal del sistema operativo o de otras aplicaciones.
- **Backdoors (puertas traseras):** es un programa malicioso usado para proporcionar al atacante un acceso remoto al ordenador comprometido no autorizado explotando las vulnerabilidades del sistema. Un backdoor funciona en el segundo plano del sistema y se esconde del usuario.

- **Spyware (software espía):** Es un malware que recopila información de un ordenador y se transmite a un equipo remoto sin el conocimiento o el consentimiento del propietario del ordenador. Habitualmente se confunde con el **Adware**.
- **Hijackers (secuestro):** Hace referencia a toda técnica ilegal que lleve consigo el adueñamiento o robo de algo (generalmente información) por parte de un atacante, es por tanto un concepto muy abierto y que puede aplicarse a varios ámbitos, de esta manera podemos encontrar con el adueñamiento o secuestro de conexiones de red, sesiones de terminal, servicios, navegador, etc.
- **Bombas lógicas:** partes de código de ciertos programas que permanecen sin realizar ninguna función hasta que son activadas (ausencia o presencia de ciertos ficheros o la llegada de una fecha/hora concreta

5.3 Amenazas físicas

Podemos caracterizar los siguientes tipos de amenazas físicas:

- **Acceso físico:** A menudo se descuida la seguridad sobre el acceso, pero hay que tener en cuenta que cuando existe acceso físico a un recurso ya no existe seguridad alguna sobre el mismo, con el consiguiente riesgo. Por ejemplo: acceso al lugar donde se encuentra un servidor de personal no autorizado, una entrada de red donde se pueda conectar un ordenador.
- **Desastres del entorno y averías del hardware:** Dentro de este grupo estarían incluidos sucesos que, sin llegar a la categoría de desastres naturales, pueden tener un impacto igual de importante si no se habilitan las medidas de protección adecuadas: hablamos, por ejemplo, de picos de sobretensión que puedan quemar componentes, apagones que afecten a los servidores, incendios, apagones y similares.
- **Radiaciones electromagnéticas:** Sabemos que cualquier aparato eléctrico emite radiaciones y que dichas radiaciones se pueden capturar y reproducir si se dispone del equipamiento adecuado.
- **Desastres naturales:** Aquí englobamos gotas frías, las inundaciones por riadas o las lluvias torrenciales puntuales, terremotos, etc.

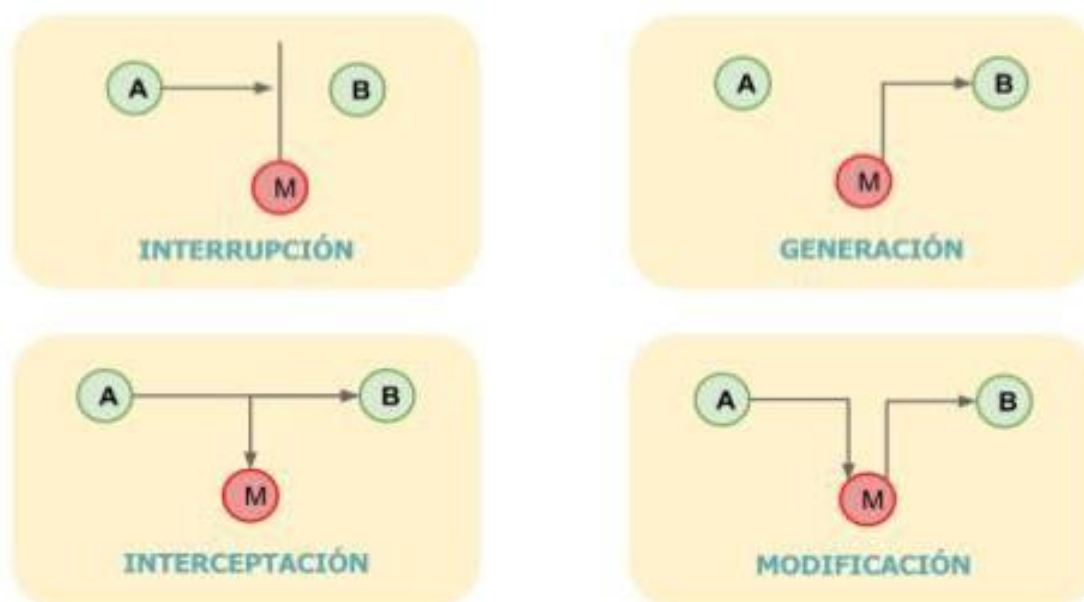
Otra clasificación de las amenazas: [Guerra informática](#)

Otros conceptos de seguridad informática:

- Pretesting
- Sextorsio
- Baiting
- Shouder Surfing,
- Dumpster diving
- [más info](#)

6 Tipos de ataques

Los principales ataques que puede sufrir un sistema si se aprovechan sus vulnerabilidades, son:



Nombre del ataque	Descripción
Interrupción	Un recurso del sistema o la red deja de estar disponible debido a un ataque.
Generación	Falsificación del sistema. Se crea un producto (por ejemplo, una página Web) difícil de distinguir del auténtico y que puede utilizarse para hacerse, por ejemplo, con información confidencial del usuario.
Interceptación	Un intruso accede a la información de nuestro equipo o a la que enviamos por la red.
Modificación	La información ha sido modificada sin autorización, por lo que ya no es válida.

Como ningún sistema es 100% seguro, diremos que un **incidente de Seguridad** es la materialización de una amenaza

Debemos:

- Minimizar las posibilidades de intrusión
- Minimizar el tiempo de:
 - Detección de intrusiones
 - Actuación ante dichas intrusiones
- Reconstruir el estado en el que estaba el sistema

7 Análisis y gestión de riesgo

El análisis de riesgos informáticos es un proceso que comprende la identificación de activos informáticos, sus vulnerabilidades y amenazas a los que se encuentran expuestos, así como su probabilidad de ocurrencia y el impacto de las mismas, a fin de determinar los controles adecuados para aceptar, disminuir, transferir o evitar la ocurrencia del riesgo.

Teniendo en cuenta que la explotación de un riesgo causaría daños o pérdidas financieras o administrativas a una empresa u organización, se tiene la necesidad de poder estimar la magnitud del impacto del riesgo a que se encuentra expuesta mediante la aplicación de controles. Dichos controles, para que sean efectivos, deben ser implementados en conjunto formando una arquitectura de seguridad con la finalidad de preservar las propiedades de confidencialidad, integridad y disponibilidad de los recursos objetos de riesgo.

8 Proceso de análisis de riesgos informáticos

El proceso de análisis de riesgo genera habitualmente un documento al cual se le conoce como matriz de riesgo. En este documento se muestran los elementos identificados, la manera en que se relacionan y los cálculos realizados. Este análisis de riesgo es indispensable para lograr una correcta administración del riesgo. La administración del riesgo hace referencia a la gestión de los recursos de la organización.

Existen diferentes tipos de riesgos como el riesgo residual y riesgo total, así como también el tratamiento del riesgo, evaluación del riesgo y gestión del riesgo entre otras.

9 Herramientas de análisis y gestión de riesgos.

9.1 Política de seguridad

Recoge las directrices u objetivos de una organización con respecto a la seguridad de la información.

Objetivo principal: concienciar a todo el personal de una organización en la necesidad de conocer qué principios rigen la seguridad y cuáles son las normas para conseguir los objetivos de seguridad planificados.

No todas las políticas de seguridad son iguales. El contenido depende de la realidad y de las necesidades de la organización para la que se elabora.

Existen algunos estándares de políticas de seguridad por países y por áreas (gobierno, medicina, militar...), pero los más internacionales son los definidos por la ISO (International Organization for Standardization).

Una política de seguridad contendrá los objetivos de la empresa en materia de seguridad del sistema de información, generalmente englobados en 5 grupos:

- Identificar las necesidades de seguridad y los riesgos que amenazan al sistema de información, así como evaluar los impactos ante un ataque puntual.
- Relacionar todas las medidas de seguridad que deben implementarse para afrontar los riesgos de cada activo o grupo de activos.
- Proporcionar una perspectiva general de las reglas y los procedimientos que deben aplicarse para afrontar los riesgos identificados en los diferentes departamentos de la organización
- Detectar todas las vulnerabilidades del sistema de información y controlar los fallos que se producen en los activos, incluidas las aplicaciones instaladas.
- Definir un plan de contingencias.

9.2 Ejemplos de herramientas de análisis y gestión de riesgos

- **MAGERIT**. Es una metodología de análisis y gestión de riesgos de los sistemas de información. En inglés Methodology for Information Systems Risk Analysis and Management.

- **PILAR.** Es un procedimiento informático-lógico para el análisis y gestión de riesgos, que sigue la metodología MAGERIT. De uso exclusivo de la Administración Pública Española.

10 Auditoría

La Auditoría Informática es un proceso llevado a cabo por profesionales especialmente capacitados para el efecto, y que consiste en recoger, agrupar y evaluar evidencias para determinar si un Sistema de Información salvaguarda el activo empresarial, mantiene la integridad de los datos ya que esta lleva a cabo eficazmente los fines de la organización, utiliza eficientemente los recursos, cumple con las leyes y regulaciones establecidas.

Hay dos tipos de auditoría informática:

- **Auditoría interna:** Es aquella que se hace desde dentro de la empresa; sin contratar a personas ajenas, en el cual los empleados realizan esta auditoría trabajan ya sea para la empresa que fueron contratados o simplemente algún afiliado a esta.
- **Auditoría externa:** Como su nombre lo dice es aquella en la cual la empresa contrata a personas de afuera para que haga la auditoría en su empresa. Auditar consiste principalmente en estudiar los mecanismos de control que están implantados en una empresa u organización, determinando si los mismos son adecuados y cumplen unos determinados objetivos o estrategias, estableciendo los cambios que se deberían realizar para la consecución de los mismos.

Tras el análisis e identificación de vulnerabilidades, la persona o equipo encargado de la auditoría emite un informe que contiene, como mínimo:

- Descripción y características de los **activos** y **procesos** analizados.
- Análisis de las **relaciones** y **dependencias** entre activos o en el proceso de la información.
- Relación y evaluación de las **vulnerabilidades** detectadas en cada activo o subconjunto de activos y procesos.
- Verificación del cumplimiento de la **normativa** en el ámbito de la seguridad.
- Propuesta de **medidas** preventivas y de corrección.

Para evaluar la seguridad de un sistema de información se necesitan herramientas de análisis:

- **Manuales.** Observación de los activos, procesos y comportamientos, mediciones, entrevistas, cuestionarios, cálculos, pruebas de funcionamiento.
- **Software específico para auditoría.** Se le reconoce por las siglas CAAT (Computer Assisted Audit Techniques). Los CAATS son herramientas de gran ayuda para mejorar la eficiencia de una auditoría, pudiendo aplicarse sobre la totalidad una parte del sistema de información. Proporcionan una imagen en tiempo real del sistema de información, realizan pruebas de control y emiten informes en los que señalizan las vulnerabilidades y puntos débiles del sistema, así como las normativas que podrían estar incumpléndose.

La auditoría puede ser **total**, sobre todo el sistema de información, o **parcial**, sobre determinados activos o procesos.

11 Plan de contingencias

El plan de contingencias es un instrumento de gestión que contiene las medidas que garanticen la continuidad del negocio protegiendo el sistema de información de los peligros que lo amenazan o recuperándolo tras un impacto.

El plan de contingencias consta de tres subplanes independientes:

- **Plan de respaldo.** Ante una amenaza, se aplican medidas preventivas para evitar que se produzca un daño.
Por ejemplo, crear y conservar en lugar seguro copias de seguridad de la información, instalar pararrayos o hacer simulacros de incendio.
- **Plan de emergencia.** Contempla qué medidas tomar cuando se está materializando una amenaza o cuando acaba de producirse.
Por ejemplo, restaurar de inmediato las copias de seguridad o activar el sistema automático de extinción de incendios.
- **Plan de recuperación.** Indica las medidas que se aplicarán cuando se ha producido un desastre. El objetivo es evaluar el impacto y regresar lo antes posible a un estado normal de funcionamiento del sistema y de la organización.
Por ejemplo, tener un lugar alternativo donde continuar la actividad si el habitual hubiese sido destruido, sustituir el material deteriorado, reinstalar aplicaciones y restaurar copias de seguridad.